

Company Research Agent

What the System Does

This system takes a company name and writes a detailed six-section business research report to help teams decide if they should invest in that company.

Inputs It Takes

Data Types: Plain text (the company name).

Sources: Public web information found via OpenAI search, along with text snippets saved as mathematical vectors in Pinecone.

Personal Data: No personal data is intended, though a company name might include a founder's name if the business is named after a person.

Outputs It Generates

Text: A PDF document containing a six-section due diligence report (Summary, Business Model, Market, Competition, Risks, and Recommendation).

Metrics & Metadata: A risk score, an opportunity score, a unique ticket ID, and workflow status flags.

Notifications: Optional automated file delivery to Notion or Telegram.

Who Is Affected by the Output

Employees: Investment analysts and deal teams who rely on the reports for corporate screening.

Businesses: The companies being researched, as the reports directly influence whether investors decide to fund them or pass.

Human Review Before Action

Yes. A human analyst must review the output before any investment decision is made.

In Practice: An analyst opens the generated PDF, cross-checks the automated risk and opportunity scores against the cited web sources, verifies the findings, and manually decides whether to approve a deal or investigate further. No automated actions or investments are made by the system itself.

Who Built It

A Solo Developer. It was built from scratch as a solo project by the repository author using Python, LangGraph, and FastAPI, combined with configured third-party services for search and storage.

Who Uses It in Production

Internal Staff: The client's investment team members, associates, and researchers use it as a starting point to speed up their manual workflow.

Based on the EU AI Act regulatory framework, this company research system is classified under the **minimal risk** tier.

Classification Justification

The system does not utilize any manipulative, deceptive, or exploitative techniques, nor does it conduct untargeted scraping of facial data or social scoring. This completely exempts it from any Article 5

prohibited practices. Furthermore, the system evaluates corporate entities and public market information for investment screening, which does not fall under any high-risk use cases listed in Annex III. It does not impact personal biometrics, critical infrastructure management, educational grading, employment hiring, or human law enforcement eligibility. Lastly, because the agent does not interact directly with end-consumers as a standard conversational chatbot, nor does it generate synthetic "deepfake" media or manipulate audio/visual content, it bypasses the special transparency obligations outlined in Article 50. As an internal back-office analytical data tool processing text for professional business-to-business (B2B) use, it is a low-impact software utility that safely qualifies for the minimal risk tier, requiring no mandatory European regulatory compliance certifications or enforcement constraints.

The Provider is me (the solo developer). According to the Act, a Provider is anyone who develops an AI system and places it on the market or puts it into service under their own name or trademark. Since I built the Python, LangGraph, and FastAPI architecture from scratch, I hold the legal status of the Provider. The Deployer is my client (and their internal investment staff). The Act defines a Deployer as any natural or legal person using an AI system under its authority in the course of a professional activity. Because the client's analysts and associates run the POST /research endpoint to screen companies for their daily professional work, they act as the Deployers.

Minimal-risk systems are completely exempt from the strict compliance, logging, and registration mandates faced by higher-risk tiers; there are no formal legal requirements under the AI Act framework itself.

However, since the system is operating within the European market, you must still comply with other established horizontal EU regulations such as GDPR

Gap analysis

Gap must be tied to a concrete legal or technical requirement, not just a vague statement like "oversight is insufficient." For the Company Research Agent, it then identifies four such gaps, even though the system is "Minimal Risk" under the AI Act:

1. GDPR – Legal basis: the tool scrapes public web data that includes personal information on founders/executives but has no documented lawful basis or process for erasure requests; it needs a Legitimate Interest Assessment and a way to delete specific embeddings in Pinecone.
2. GDPR – Cross-border transfers: using OpenAI and Pinecone may send EU personal data to US servers without SCCs or reliance on the EU-US Data Privacy Framework; it must switch to EU regions or update contracts.

3. Cyber/ePrivacy – API auth: the public **POST /research** endpoint is not access-controlled, risking abuse and data leakage; it needs strong authentication (e.g., OAuth2 or bearer tokens).
4. Trade Secrets – Retention/isolation: reports and vectors are stored indefinitely without clear retention limits or tenant isolation, risking exposure of confidential investment strategies; it needs time-bound deletion and separate, isolated vector namespaces.

Remediation

1. GDPR: Legal Basis for Executive Data Processing

Data Scrubbing: Add a dedicated data-scrubbing utility function to the FastAPI backend.

Vector Deletion: Use the Pinecone client to hard-delete records matching specific individual metadata or text content upon receiving a deletion request.

Documentation: Write a one-page Legitimate Interest Assessment (LIA) document.

Justification: State that processing corporate officer names is necessary for investment risk prevention and has minimal privacy impact.

2. GDPR: Cross-Border Data Transfers

EU Residency: Change initialization URLs or region parameters to enforce EU residency.

Server Pinning: Pin OpenAI and Pinecone developer console projects to European servers.

Endpoint Updates: Update FastAPI environment variables to target an EU endpoint if using Azure OpenAI.

3. Cyber/ePrivacy Directive: API Endpoint Authentication

Endpoint Security: Secure the FastAPI POST /research endpoint.

Dependency Check: Inject a mandatory dependency check using HTTPBearer.

Access Control: Ensure only requests with a valid token can trigger the agent.

4. EU Trade Secrets Directive: Data Retention and Isolation

Cleanup Tasks: Add a FastAPI background task to automatically delete old PDF files in the workspace after a set delay.

Data Segregation: Use Pinecone namespaces during embedding upserts to isolate client data.

Contamination Prevention: Prevent cross-contamination of company intelligence across different clients.

MEMORANDUM

TO: Head of Product

FROM: Lead AI Systems Architect

DATE: May 26, 2026

SUBJECT: Compliance Assessment and Risk Map for the Company Research Agent System Classification

Under the European Union Artificial Intelligence Act, the Company Research Agent is classified as a Minimal Risk system because it operates strictly as an internal back-office analytical data tool processing public text for professional business-to-business (B2B) use, avoiding any prohibited or high-risk categories listed in the law.

Role Map

The Provider (Our Role): As the developer who designed, coded, and built the Python, LangGraph, and FastAPI infrastructure from scratch, we legally hold the status of the Provider under the Act.

The Deployer (Your Role / The Client): As the operational business using the system within a professional activity to assist staff with daily corporate screenings, your organization legally holds the status of the Deployer.

Key Findings

While our Minimal Risk status completely exempts the system from strict AI Act registration requirements, the product remains subject to broader European laws. We have identified three critical compliance gaps that currently prevent a secure production launch:

Unprotected Personal Data: The system extracts the names and career histories of company founders and executives from public websites; however, we currently lack a documented legal justification to hold this information, and we do not have a feature allowing individuals to request that their data be deleted from our vector database.

Cross-Border Data Storage: Our automated system routes search queries through standard external cloud servers that may store or process data outside of Europe, which violates strict European cross-border data privacy rules.

Open Access Security Risks: The software endpoint that triggers new reports does not require security logins or authentication, allowing unauthorized users to freely generate research, drain our software budget, and potentially expose sensitive client pipeline targets.

Recommended Next Steps

To resolve these gaps and protect our intellectual property, we recommend the following phased deployment plan:

Phase 1 (Security Integration): Lock down the main search software endpoint immediately by injecting a mandatory secure API access key verification layer into our backend code.

Phase 2 (Data Residency Updates): Update the code configuration settings for our third-party data pipelines to ensure all text indexing and cloud processing are hard-pinned exclusively to European server locations (e.g., Frankfurt or Sweden).

Phase 3 (Privacy Tools): Write a script that enables administrators to manually purge specific target data chunks from our vector indexes upon request, and publish a clear data processing policy.

External Review: Once Phase 1 and Phase 2 are complete, secure an independent data protection assessment from an external privacy professional to formally sign off on our founder data processing strategy before pushing the software live to end-users.

Caveats

This memorandum is for internal product strategy and planning purposes only. It does not constitute a formal legal opinion, an official regulatory conformity assessment, or a certified compliance audit under European law.

Thank You

Olawuyi Adetunji Abiodun